

Security+ 3.2 · Firewall Types

Mestre CyberSec · Aula 3.2 — Firewall Types (8:00) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Evolução: ACL stateless; stateful (lembra a conexão); NGFW (aplicação+user+threat intel+SSL inspection); UTM (NGFW+IPS+AV anti-spam num appliance); WAF (protege o HTTP/S do site: SQLi/XSS/CSRF).

💡 Highlights que a prova CompTIA cobra

- Stateful lembra a conexão; stateless é por pacote
- NGFW = stateful + aplicação + usuário + threat intelligence
- WAF (L7) protege o web app; NGFW protege o tráfego da rede

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'application-aware firewall'=NGFW
- 'inspects HTTP for SQL injection'=WAF

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Lista de Controle de Acesso (ACL)

Lista sequencial de regras de permissão/negação aplicada em roteadores ou firewalls stateless para filtrar tráfego por IP e porta de origem/destino. As regras são processadas de cima para baixo e a primeira que casa vence.

⚠ **Armadilha CompTIA:** ACL = mecanismo típico do firewall STATELESS. Não rastreia conexões: o tráfego de retorno precisa de regra explícita. Lembre-se: 'first match wins'.

• Firewall sem Estado (Filtro de Pacotes)

Firewall que filtra cada pacote individualmente contra regras de ACL, sem memória de pacotes anteriores ou do estado da conexão. Não consegue saber se o tráfego pertence a uma sessão já estabelecida.

⚠ **Armadilha CompTIA:** Gatilhos de prova: 'per-packet', 'no connection awareness', 'uses ACLs' = stateless. Distinção-chave: stateless avalia o pacote isolado; stateful avalia a conexão inteira.

• Firewall com Estado (Stateful)

Firewall que mantém uma tabela de estado das conexões ativas, acompanhando cada sessão de ponta a ponta e liberando automaticamente o tráfego de retorno de fluxos estabelecidos.

⚠ **Armadilha CompTIA:** 'Remembers the connection' / 'tracks sessions' = stateful. ARMADILHA: stateful puro NÃO é application-aware nem inspeciona conteúdo — isso é NGFW.

• Firewall de Próxima Geração (NGFW)

Firewall application-aware que combina filtragem stateful com identificação e controle de aplicações, reconhecimento da identidade do usuário, threat intelligence e inspeção com descriptografia SSL/TLS.

⚠ **Armadilha CompTIA:** 'Application-aware firewall' = NGFW. Se a questão cita 'user + application + threat intelligence' ou 'decrypts SSL/TLS', é NGFW — NÃO escolha WAF, que protege apenas o web app.

• Gestão Unificada de Ameaças (UTM)

Appliance de segurança 'tudo em um' que reúne firewall com IPS, antivírus, anti-spam e outros serviços de segurança em um único dispositivo (na prática, NGFW + várias proteções integradas).

⚠ **Armadilha CompTIA:** 'All-in-one security appliance' com firewall + IPS + AV + anti-spam = UTM. Distinção para a prova: UTM enfatiza os serviços empilhados num appliance; NGFW enfatiza aplicação/usuário/threat intel.

• Firewall de Aplicação Web (WAF)

Firewall de Camada 7 posicionado na frente de uma aplicação web que inspeciona o tráfego HTTP/HTTPS para bloquear ataques web como SQL injection, XSS e CSRF.

⚠ **Armadilha CompTIA:** 'Inspects HTTP for SQL injection' = WAF. Distinção de ouro: WAF protege a aplicação web/servidor web (L7); NGFW protege o tráfego da rede como um todo.

• Inspeção SSL/TLS

Recurso do NGFW que descriptografa o tráfego cifrado com TLS (atuando como intermediário confiável), inspeciona o conteúdo em busca de ameaças e recifra antes de encaminhar.

⚠ **Armadilha CompTIA:** 'Firewall decrypts and examines HTTPS/TLS traffic' → NGFW. Firewalls stateless/stateful só veem cabeçalhos e não conseguem inspecionar conteúdo cifrado.

• Injeção de SQL (SQLi)

Ataque de injeção que envia comandos SQL maliciosos por entradas não validadas de uma aplicação web para ler ou manipular o banco de dados backend.

⚠ **Armadilha CompTIA:** SQLi é o exemplo clássico de ataque web na prova: o dispositivo que bloqueia SQLi no tráfego HTTP é o WAF (mitigações complementares: validação de entrada e queries parametrizadas).

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma equipe de rede usa ACLs de roteador que permitem TCP 443 de entrada para um servidor web público e negam todo o restante. Durante uma revisão, um analista descobre que pacotes craftados com a flag ACK ativada conseguem chegar ao servidor mesmo sem handshake TCP concluído. O roteador avalia cada pacote independentemente e não possui tabela de sessões. Qual tipo de firewall deve ser implementado para rastrear sessões TCP e permitir automaticamente o tráfego de retorno?

- A) Firewall stateless de filtragem de pacotes
- B) Firewall stateful
- C) Firewall de aplicação web
- D) Appliance de gerenciamento unificado de ameaças

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa de e-commerce possui um NGFW permitindo HTTPS para seus servidores web. Testes de penetração conseguem enviar instruções SQL maliciosas e payloads de script por formulários normais de carrinho de compras, e o NGFW não os bloqueia porque trata o tráfego como HTTPS permitido. Qual tipo dedicado de firewall é mais adequado para inspecionar o conteúdo de requisições HTTP e bloquear SQLi e XSS?

- A) Filtro de pacotes stateless
- B) Firewall stateful
- C) Firewall de aplicação web
- D) Gateway de inspeção SSL/TLS

QUESTÃO 3 · CENÁRIO DE EXAME

Uma pequena empresa possui dispositivos separados para firewall, IPS, verificação antivírus, filtragem de spam e filtragem de conteúdo web em sua filial. O orçamento de TI não permite renovar vários appliances, e o administrador deseja um único dispositivo que forneça essas proteções em camadas. Qual tipo de solução de firewall melhor atende a esse requisito?

- A) Filtro de pacotes stateless
- B) Firewall stateful
- C) Firewall de próxima geração
- D) Appliance de gerenciamento unificado de ameaças

QUESTÃO 4 · CENÁRIO DE EXAME

Um arquiteto de segurança precisa aplicar políticas com base em grupos de usuários do Active Directory, identificar aplicações SaaS mesmo quando usam HTTPS, consumir feeds de inteligência de ameaças em tempo real e descriptografar tráfego TLS de saída para inspeção. Qual tipo de firewall foi projetado para atender a todos esses requisitos?

- A) Firewall de filtragem de pacotes
- B) Firewall stateful
- C) Firewall de próxima geração
- D) Firewall de aplicação web

QUESTÃO 5 · CENÁRIO DE EXAME

Usuários relatam falhas intermitentes de acesso depois que um administrador aplica uma ACL de entrada em um roteador que permite apenas TCP 80 para um servidor web. O administrador descobre que o tráfego de retorno do servidor para os clientes também é avaliado por uma ACL de saída separada e é descartado, a menos que uma regra de permissão adicional seja adicionada. Qual limitação da abordagem atual de firewall isso demonstra?

- A) Ela não consegue realizar inspeção stateful de conexões estabelecidas
- B) Ela não consegue descriptografar tráfego SSL/TLS
- C) Ela não consegue inspecionar corpos de requisições HTTP
- D) Ela não consegue autenticar usuários no Active Directory

QUESTÃO 6 · CENÁRIO DE EXAME

O NGFW de uma empresa está configurado para bloquear downloads maliciosos, mas a maior parte do tráfego web dos funcionários agora é HTTPS. O firewall vê apenas fluxos criptografados e não consegue aplicar assinaturas de aplicação ou ameaça ao payload. Qual recurso a equipe de segurança deve habilitar no NGFW para inspecionar o conteúdo de sessões criptografadas?

- A) Avaliação de ACL stateless
- B) Inspeção SSL/TLS
- C) Política de firewall de aplicação web
- D) Concentrador de rede privada virtual

QUESTÃO 7 · CENÁRIO DE EXAME

Uma aplicação web pública está atrás de um firewall stateful que permite HTTPS de entrada. Atacantes estão tentando cross-site request forgery e injeção de script malicioso por parâmetros HTTP legítimos. A equipe de segurança precisa de um controle que entenda métodos HTTP, cabeçalhos, cookies e parâmetros de formulário e possa bloquear esses ataques antes que cheguem à aplicação. Qual tipo de firewall é mais apropriado?

- A) Filtro de pacotes stateless
- B) Firewall stateful
- C) Firewall de aplicação web
- D) Appliance de gerenciamento unificado de ameaças

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de rede precisa permitir que funcionários remotos acessem uma aplicação interna via TCP 3389. A regra atual do firewall permite TCP 3389 da internet para o servidor da aplicação. Uma revisão de segurança sinaliza que o firewall também permite pacotes não solicitados que parecem fazer parte de uma sessão existente porque nunca verifica números de sequência nem estado de conexão. Qual tipo de firewall está atualmente implantado?

- A) Firewall stateless de filtragem de pacotes
- B) Firewall stateful
- C) Firewall de próxima geração
- D) Firewall de aplicação web

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa de médio porte está comparando plataformas de firewall. A equipe de segurança deseja políticas cientes de aplicação, integração de identidade de usuário e inteligência de ameaças, mas também exige antivírus, anti-spam e filtragem de conteúdo integrados no mesmo appliance para simplificar implantações em filiais. Qual categoria de solução melhor descreve esse conjunto combinado de recursos?

- A)** Filtro de pacotes stateless
- B)** Firewall stateful
- C)** Firewall de próxima geração
- D)** Appliance de gerenciamento unificado de ameaças

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa deseja impedir que funcionários usem aplicações de armazenamento em nuvem não autorizadas. O firewall atual verifica apenas endereços IP e portas, então muitas aplicações são permitidas por TCP 443. A equipe de segurança precisa identificar a aplicação por seus padrões de tráfego e aplicar políticas com base no departamento do usuário. Qual tecnologia de firewall deve ser selecionada?

- A)** Filtro de pacotes stateless
- B)** Firewall stateful
- C)** Firewall de próxima geração
- D)** Firewall de aplicação web

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Firewall stateful

Um firewall stateful mantém uma tabela de sessões e rastreia o estado das conexões TCP. Ele consegue determinar se um pacote pertence a uma sessão estabelecida ou relacionada e permitir automaticamente o tráfego de retorno, diferentemente de uma ACL stateless que avalia cada pacote isoladamente.

Questão 2: Alternativa C — Firewall de aplicação web

Um firewall de aplicação web atua na camada de aplicação para tráfego HTTP e HTTPS. Ele analisa requisições e respostas, entende parâmetros web e pode bloquear ataques como injeção SQL e cross-site scripting. A inspeção SSL/TLS descriptografa o tráfego, mas por si só não aplica lógica de ataque de aplicação web.

Questão 3: Alternativa D — Appliance de gerenciamento unificado de ameaças

O Gerenciamento Unificado de Ameaças é um appliance de segurança tudo-em-um que normalmente combina firewall, IPS, antivírus, anti-spam e filtragem de conteúdo. Ele foi projetado para simplificar a implantação e o gerenciamento em organizações que precisam de várias proteções em um único dispositivo.

Questão 4: Alternativa C — Firewall de próxima geração

Um firewall de próxima geração integra reconhecimento de aplicação, identidade de usuário, inteligência de ameaças e, muitas vezes, inspeção SSL/TLS. Um firewall stateful tradicional rastreia principalmente conexões, enquanto um firewall de aplicação web foca na proteção de aplicações HTTP/S em vez de fornecer controle amplo de identidade e aplicação.

Questão 5: Alternativa A — Ela não consegue realizar inspeção stateful de conexões estabelecidas

Uma ACL stateless não mantém uma tabela de estado de conexão, então o tráfego de retorno precisa ser explicitamente permitido por outra regra. Um firewall stateful reconheceria o tráfego como parte de uma sessão estabelecida e o permitiria conforme a política, sem exigir regras separadas de retorno.

Questão 6: Alternativa B — Inspeção SSL/TLS

A inspeção SSL/TLS permite que o firewall descriptografe, inspecione e recriptografe o tráfego criptografado. Isso permite que assinaturas de aplicação e ameaça examinem payloads dentro de sessões HTTPS. ACLs stateless e concentradores VPN não inspecionam payloads criptografados, e um WAF normalmente foca na proteção de aplicações web de entrada.

Questão 7: Alternativa C — Firewall de aplicação web

Um firewall de aplicação web é projetado especificamente para inspecionar tráfego de camada de aplicação HTTP e HTTPS, incluindo métodos, cabeçalhos, cookies e parâmetros. Ele pode bloquear ataques como cross-site request forgery, cross-site scripting e injeção SQL. Firewalls stateful rastreiam principalmente conexões e não entendem o conteúdo de requisições web.

Questão 8: Alternativa A — Firewall stateless de filtragem de pacotes

Um firewall stateless de filtragem de pacotes toma decisões apenas com base em informações individuais do cabeçalho do pacote, como endereços IP de origem e destino, portas e protocolo. Ele não mantém tabela de sessões nem verifica números de sequência, então pode permitir pacotes que apenas parecem corresponder a uma sessão. Firewalls stateful rastreiam o estado da conexão.

Questão 9: Alternativa D — Appliance de gerenciamento unificado de ameaças

O Gerenciamento Unificado de Ameaças normalmente combina recursos de firewall de próxima geração com serviços adicionais de segurança, como antivírus, anti-spam e filtragem de conteúdo em um único appliance. Essa abordagem tudo-em-um é frequentemente escolhida para implantações mais simples em filiais, enquanto um NGFW sozinho pode não incluir todos os serviços de UTM.

Questão 10: Alternativa C — Firewall de próxima geração

Um firewall de próxima geração consegue identificar aplicações por suas características de tráfego, mesmo quando usam portas comuns como TCP 443, e pode aplicar políticas com base na identidade ou no grupo do usuário. Um firewall stateful rastreia principalmente conexões, enquanto um WAF protege aplicações web de entrada em vez de controlar o uso de SaaS pelos funcionários.

